

Controls and compliance checklist

To complete the controls assessment checklist, refer to the information provided in the [scope, goals, and risk assessment report](#). For more details about each control, including the type and purpose, refer to the [control categories](#) document. Then, select “yes” or “no” to answer the question: *Does Botium Toys currently have this control in place?*

Controls assessment checklist

Yes	No	Control
	- Least Privilege Explanation : Currently all employees in the company have access to customer data. Privilege needs to be minimized or limited only to those who are authorized to access it, but not anyone. - Disaster recovery plans Explanation : The company does not have any kind of disaster recovery plan. It is a very serious matter to be concerned with, as well as it does not have any backups of critical customer data. This issue should be resolved in time to avoid risk that can occur with data loss in case of any disaster.	
	- Password policies: Explanation : Password policy exists, but at a very bare minimum level. This is not sufficient. Companies should implement a policy that allows customers to use the services only with a strong password. At a basic level a strong password has some rules such as password should be of minimum 8 character, should include uppercase, lowercase and symbols. In case required, here is a sample of strong password : &QT70uop+=&ef& - Separation of duties : Explanation :	

Not implemented, this is another big vulnerability of an organization. It can cause misuse of a person's right to access any information in the organization. All the employees, BOARD members, CEO, Managers, customers should have their respective right to access certain data. They should be allowed to access the information which is particularly required to them only.

- Firewall :
Explanation :
The shop's IT department has a firewall, that's a good thing to be appreciated. It is recommended that IT teams do a regular monitoring to check its performing status and updates and upgrades it timely.
- Intrusion detection system (IDS):
Explanation:
IDS is not installed. This is one of the biggest vulnerabilities that a shop is compromising. This can make a shop a victim of IDS attackers anytime and the shop can ruin at any time. It is strongly recommended that the shop installs IDS properly as fast as possible to protect sensitive data from being stolen.
- Backups:
Explanation:
Companies do not have disaster recovery plans. This is another serious issue. In case any disaster occurred and all data got lost, the company has to face a serious problem of data recovery. Or data will not recover.
- Antivirus software:
Explanation:
Antivirus software is installed and monitored by the IT department regularly.
- Manual monitoring, maintenance, and intervention for legacy systems
Explanation:
The list of assets notes the use of legacy systems. The risk assessment indicates that these systems are monitored and maintained, but there is not a regular schedule in place for this task and procedures/ policies related to intervention are unclear, which could place these systems at risk of a breach.

- Encryption:
Explanation:
The encryption system is not implemented in the company. This is another biggest threat to the company. Threat actors can misuse this vulnerability anytime to fulfill their goal.
- Password management system:
Explanation:
There is no password management system. Companies should set a criteria to use strong passwords that can't be cracked easily by threat actors.
- Locks (offices, storefront, warehouse):
Explanation:
The store's physical location, which includes the company's main offices, store front, and warehouse of products, has sufficient locks.
- Closed-circuit television (CCTV) surveillance
Explanation:
CCTV is installed/functioning at the store's physical location.
- Fire detection/prevention (fire alarm, sprinkler system, etc.)
Explanation:
The company has a well functioning fire detection system.

To complete the compliance checklist, refer to the information provided in the [scope, goals, and risk assessment report](#). For more details about each compliance regulation, review the [controls, frameworks, and compliance](#) reading.

Then, select “yes” or “no” to answer the question: *Does Botium Toys currently adhere to this compliance best practice?*

Compliance checklist

Payment Card Industry Data Security Standard (PCI DSS)

Yes	No	Best practice
		- Only authorized users have access to customers' credit card information. Explanation: Anyone can access credit card information. This is an illegal, immoral, unethical practice. Companies can face any legal action if this issue is not solved. - Credit card information is stored, accepted, processed, and transmitted internally, in a secure environment. Explanation: Currently encryption has not been used to protect customer data, and data transfer in a secure environment. Companies should take action as soon as possible to solve this issue. - Implement data encryption procedures to better secure credit card transaction touchpoints and data. Explanation: This has not been implemented. - Adopt secure password management policies. Explanation: A company has not adopted a secure password management policy. Weak and simple passwords can be cracked anytime by threat actors.

General Data Protection Regulation (GDPR)

Yes	No	Best practice
		- E.U. customers' data is kept private/secured. Explanation: <i>The company does not currently use encryption to better ensure the confidentiality of customers' financial information.</i> - There is a plan in place to notify E.U. customers within 72 hours if their data is compromised/there is a breach. Explanation: <i>There is a plan to notify E.U. customers within 72 hours of a data</i>

breach.

- Ensure data is properly classified and inventoried.
Explanation:
Current assets have been inventoried/listed, but not classified.
- Enforce privacy policies, procedures, and processes to properly document and maintain data.
Explanation:
Privacy policies, procedures, and processes have been developed and enforced among IT team members and other employees, as needed.

System and Organizations Controls (SOC type 1, SOC type 2)

Yes	No	Best practice
	• User access policies are established. Explanation: There is no user access policy established	
	• Data integrity ensures the data is consistent, complete, accurate, and has been validated. Explanation: Data integrity is in place	
	• Data is available to individuals authorized to access it. Explanation: Customers can access their data when needed.	

Recommendations (optional): *Botium Toys* currently is really unsecure because it lacks to follow the security standards or (NIST RMF) or NIST CSF, or ISO standard. The shop needs to implement an appropriate framework to prevent any kind of cybersecurity threat in the future. The best approach for the shop can be to implement

NIST CSF framework guidelines and ensure OWASP security principles. There is a big risk involved in the shop presently of threat and attacks due to lack of implementing proper cybersecurity measures to ensure security.